

SentinelAPI

Autonomous Differential API Security Testing

Ingesting OpenAPI 3.x specifications, dynamically authenticating multiple test personas, learning ground-truth resource ownership without brute-forcing, and executing differential response analysis to eliminate authorization blindspots before production.

OWASP API #1 COVERAGE

BOLA / IDOR & BFLA Detection

Automated cross-user access tests across multi-tenant boundaries with zero manual test script creation.

EMPIRICAL EVIDENCE

Live Reproduction & cURL PoCs

Zero false positives. Active live re-probes verify 100% reproducibility with shell-safe curl PoCs.

ENTERPRISE SAFETY

Strict Scope Guards & Egress Filter

20 RPS rate caps, zero secrets stored, and an evidence-only AI boundary that never accesses raw credentials.

Lead Security Architect: [Tanuj](#)

Full-Stack & Security Engineering

<https://github.com/x03tanuj/sentinel-api>

The API Authorization Blindspot in Modern Software



OWASP #1 CRITICAL THREAT Broken Object Level Authorization (BOLA / IDOR)

BOLA remains the most rampant and catastrophic flaw in cloud APIs. An authenticated attacker merely alters a numeric ID (`/orders/101` → `/orders/102`) to view, modify, or delete another customer's confidential financial, identity, or medical records.



CONVENTIONAL TOOLS FAIL DAST & SAST Are Blind to Multi-User Business Logic

Traditional scanners search for syntax anomalies like SQL injection and XSS payloads. They operate in a single-user sandbox and have zero contextual understanding of multi-tenant authorization boundaries, role hierarchies, or cross-account access rules.



VELOCITY GAP Manual Penetration Testing Doesn't Scale in Agile CI/CD

Engineering teams deploy microservices dozens of times weekly. Manual security audits are expensive, quarterly, and too slow to catch day-to-day authorization regressions before code hits production environments.



SILENT EXPLOITATION Flaws Evade WAFs and Perimeter Defenses

Because BOLA requests use valid HTTP formats and legitimate credentials, target APIs respond with standard `200 OK` payloads. Web Application Firewalls (WAFs) see normal traffic, resulting in undetected leaks and severe GDPR / HIPAA compliance penalties.

Autonomous Differential API Security Testing

SentinelAPI automates end-to-end authorization security audits by ingesting OpenAPI contracts, discovering legitimate resource ownership across multiple authenticated personas, and executing differential response analysis to mathematically prove access violations.

1. SPEC-DRIVEN ATTACK SURFACE MAPPING

Contract Validation & Risk Prioritization

Ingests OpenAPI 3.x contracts from URLs or JSON/YAML. Automatically validates schemas, dereferences complex circular \$ref pointers, and assigns preliminary risk rankings to state-changing operations and privileged routes.

2. MULTI-PERSONA GROUND-TRUTH MATRIX

Zero-Guesswork Ownership Discovery

Authenticates distinct test personas (userA, userB, admin) via JWT. Queries legitimate collection endpoints to learn owned resources without brute-force ID guessing, building a mathematical Allow/Deny expectation matrix.

3. DIFFERENTIAL RESPONSE ANALYSIS

Mathematical Distance & Field Divergence

Dispatches rate-limited cross-user attack probes. Analyzes baseline vs attack responses using weighted Jaccard similarity distance, status-code divergence, and undeclared sensitive field classification to detect breaches.

4. EMPIRICAL PROOF & REPRODUCIBLE POCS

Zero False Positives with cURL Evidence

Actively re-probes top findings against the live API to empirically prove reproducibility. Generates copy-pasteable, shell-safe cURL PoCs with masked \$TOKEN placeholders for immediate engineering remediation.



Proprietary Judged IP: 6 Core Engineering Engines

ENGINE 1

Attack Surface Mapper

Parses and dereferences OpenAPI 3.x contracts with circular `$ref` protection. Extracts parameters, endpoints, and auth constraints, computing preliminary risk scores for targeted probing.

ENGINE 2

Identity & Execution Engine

Orchestrates multi-user persona sessions via JWT/Bearer auth. Dispatches probes through token-bucket rate limiter (20 RPS) and immutable host allowlists (`assert_in_scope`).

ENGINE 3

Matrix Compiler

Queries legitimate profile & collection GET endpoints to dynamically discover resources owned by each persona, compiling an explicit mathematical Allow/Deny expectation matrix.

ENGINE 4

Differential Analyzer

Compares attack vs legitimate baseline responses using weighted Jaccard similarity distance, status-code divergence, and undeclared sensitive field leakage classification.

ENGINE 5

6 Security Checks

Dedicated detection modules for BOLA/IDOR (API1), Broken Authentication (API2), Excessive Data Exposure (API3), Rate Limiting (API4), BFLA Privileges (API5), and Input Handling (API8).

ENGINE 6

Explainable Risk & Confidence

Replaces CVSS guesswork with a transparent 4-part score: Impact (40) + Exploitability (25) + Sensitivity (30) + Evidence Strength (15), augmented with empirical live reproduction.

Enterprise Safety Guardrails & Zero-Trust Design

 ENFORCED SAFETY & EXECUTION BOUNDARIES

- Scope Guard (`assert_in_scope`)**
Hardcoded validation against explicit `ALLOWED_HOSTS`. Probes to external domains or unauthorized IPs are terminated immediately with `ScopeViolationError`.
- Token-Bucket Rate Limiter (20 RPS)**
Strictly throttles outbound probes to 20 requests/sec, preventing target denial-of-service, API degradation, or accidental lockout of customer services.
- Strict Request Budget Cap (1,000 req)**
Hard cap prevents recursive endpoint traps, circular crawler loops, and runaway test case generation during automated audits.
- Defense-in-Depth Token Scrubbing**
JWT tokens, passwords, and Authorization headers are permanently redacted before persistence or UI rendering. PoCs use `$TOKEN` placeholders.
- Shielded State Cleanup**
Scanner-created test records are tracked and deleted in shielded `finally` blocks, leaving zero test artifacts behind on target APIs.

 EVIDENCE-ONLY AI & ARCHITECTURAL STACK

- Strict AI Separation of Concerns**
The LLM (Groq, OpenRouter, Gemini) provides natural-language remediation and code fixes. The model NEVER participates in vulnerability detection or severity scoring.
- Pre-Flight Data Egress Assertion**
`assert_payload_safe()` regex scans every outgoing prompt. Egress is immediately aborted if tokens, SSNs, credit cards, or internal IPs are detected.
- Deterministic Offline Fallbacks**
If the LLM provider times out, returns malformed JSON, or exceeds rate limits, pre-compiled deterministic remediation templates activate seamlessly.
- FastAPI Async Backend & Atomic Storage**
Python 3.11/3.14 with FastAPI async orchestrator, Pydantic v2 validation, in-memory atomic JSON store (`scans.json`), and real-time SSE streaming.
- Tactical Developer UI**
React 19, Vite, Tailwind CSS with tactical tokens, WCAG AA contrast compliance, and responsive dark-mode developer dashboards.

Developer-First Tactical Triage & Differential Inspector

SentinelAPIv0.9.0-alpha

Scan History

Target: target_api:9000 (url:target_api:900...

Scope Guard: Active (allow-listed only)

SCANNING

Run Scan

WORKSPACE // Results Triage

[RUNNING]

Findings

Authorization Matrix

Attack Surface

Analytics

Export

targetApi:9000

Explain top 5

AI calls: 0 / 15

AI Executive Summary

verify before use

Generate AI Summary

No executive summary generated yet.

Click "Generate AI Summary" to synthesize an overview of audit findings and business risk.

ENDPOINTS AUDITED

0 / 12100% surface mapped

CRITICAL FINDINGS

CLEAN0BOLA & write access

HIGH SEVERITY

CLEAN0State modification

MEDIUM SEVERITY

CLEAN0Data exposure

VERIFIED CONTROLS

27Expected 403 Denied

TARGET FINDINGS STREAM

0 of 0 Issues

All0Critical0High0Medium0Low0Info0Secure

Search findings (e.g. /)

All Checks

Min Confidence:0%

Select a finding from the left rail to inspect differential evidence.

SentinelAPIv0.9.0-alpha

Scan History

Target: target_api:9000 (url:target_api:900...

Scope Guard: Active (allow-listed only)

READY

Run Scan

API5:2023by: userB

GET /users/{id}

CRITICAL

Excessive Data Exposure on /users/{id}

API3:2023by: userA

GET /users/{id}

CRITICAL

Excessive Data Exposure on /users/{id}

API3:2023by: userB

GET /orders/{id}

HIGH

Broken Object Level Authorization (BOLA/IDOR) on /orders/{id}

API1:2023by: userB

GET /orders/{id}

HIGH

Broken Object Level Authorization (BOLA/IDOR) on /orders/{id}

PII, credentials & financial records exposure

Empirical reproduction & differential confidence

> bash - curl [Press 'c' to copy]

Copy cURL

Note: export TOKEN=<attacker token> first

curl -X GET http://target_api:9000/orders/101 -H "Authorization: Bearer \$TOKEN"

DUAL-IDENTITY RESPONSE DIFFERENTIAL

Left: Owner Baseline vs Right: Attacker Probe

Legitimate Owner (Legitimate Owner)200 OK

{ "id": 101, "user_id": 1, "items": [{ "product_id": 1, "qty": 1 }, { "product_id": 2, "qty": 1 }], "total": 180, "shipping_address": "123 Elm St, Springfield, IL 62701", "status": "delivered" }

userB (Attacker Persona)Expected: 403 ForbiddenActual: 200 OK

{ "id": 101, "user_id": 1, "items": [{ "product_id": 1, "qty": 1 }, { "product_id": 2, "qty": 1 }], "total": 180, "shipping_address": "123 Elm St, Springfield, IL 62701", "status": "delivered" }

"shipping_address": "12*****01" [LEAKED PII]

Results Triage Workspace: Real-Time Stream

Live telemetry HUD with verified control counts, severity badges, and one-click filtering by OWASP category, status, and path template.

Differential Finding Inspector: Mathematical Evidence

Side-by-side baseline vs attack diff showing BOLA breach (200 OK vs 403 Forbidden), leaked PII fields, 4-factor risk breakdown, and copy-paste cURL PoC.

Zero Guesswork: Every finding includes empirical reproduction status (100% verified), exact response diffs, and reproducible curl commands.

Shift-Left Automated Security Quality Gate for CI/CD

HEADLESS CI GATE CLI

scripts/ci_gate.py

Runs headlessly in any CI/CD pipeline (GitHub Actions, GitLab CI, CircleCI).
Evaluates findings against configurable policy thresholds (`--fail-on CRITICAL,HIGH`) and breaks builds with exit code 1.

AUTOMATED SARIF & EXPORTS

GitHub Security Tab

Automatically renders and exports deterministic SARIF, Markdown, and JSON audit reports. Findings appear natively in GitHub Security code scanning alerts inside pull requests.

HERMETIC TEST SANDBOX

Docker Compose Testbed

Ships with realistic vulnerable sandboxes (Retail Store, MedPulse Healthcare, FinTech API) on ports 9000-9003. When `SECURE_MODE=true` is toggled, verifies 100% controls pass.

GITHUB ACTIONS WORKFLOW INTEGRATION (.github/workflows/ci.yml)

```
# 1. Trigger automated security scan against PR test environment
python -m app.cli scan --spec http://api:8000/openapi.json --base-url http://api:8000 --json-out findings.json

# 2. Enforce quality gate (fails build on CRITICAL / HIGH findings with confidence ≥ 0.70)
python scripts/ci_gate.py --findings findings.json --fail-on CRITICAL,HIGH --min-confidence 0.70
```

Commercial Roadmap: Beyond the Hackathon

PHASE A · COMMERCIAL SAAS

Open-Source CLI + Paid Cloud Dashboard

Maintain open-source CLI runner for individual developers and local CI gates. Commercialize a hosted, multi-tenant SaaS dashboard for engineering organizations with centralized RBAC, historical risk trending, team collaboration, and vulnerability triage workflows.

PHASE B · ENTERPRISE AUTH

Enterprise OAuth2 & SSO Negotiation

Extend beyond static JWTs to automated OAuth2 / OIDC PKCE flow negotiation, SAML handshakes, and mTLS client-certificate authentication for complex enterprise banking, fintech, and healthcare environments.

PHASE C · COMPLIANCE ENGINES

Custom Regulatory Policy Mappings

Provide declarative YAML policy mappings translating authorization findings directly into HIPAA, PCI-DSS, SOC 2, and ISO 27001 audit deliverables with automated executive PDF sign-off reports.

PHASE D · DISTRIBUTED MESH

Distributed Scanner Mesh & Cloud Storage

Deploy distributed Kubernetes scanner workers capable of concurrently auditing large microservice meshes, backed by MongoDB and PostgreSQL persistence adapters for multi-year enterprise audit archiving.

Team & Project Summary — Questions & Live Demo

CORE TEAM & ARCHITECTURAL CONTRIBUTIONS

Tanuj — Lead Security Architect & Full-Stack Engineer

Amity University · AmiHacks 2026 (Track C: Cybersecurity)

- **Core Security Engine:** Differential response analyzer, ground-truth authorization matrix compiler, and 6 modular OWASP security checks.
- **Execution & Safety:** Token-bucket HTTP executor, strict immutable scope guard, rate/budget caps, and multi-persona JWT orchestrator.
- **Backend & Storage:** FastAPI async orchestrator, real-time SSE telemetry stream, and atomic JSON store with secret leak guards.
- **Tactical Web UI:** React 19/Vite dashboard, Results Triage Workspace, Authorization Heatmap, and Differential Inspector.
- **CI Quality Gate:** Headless `ci_gate.py`, Docker Compose testbed, live empirical reproduction, and zero-egress AI analyst boundary.

PROJECT SUMMARY & LIVE ACCESS

“SentinelAPI stops API authorization breaches before code hits production — fully autonomous, mathematically verified, with reproducible evidence and zero secrets leaked.”

GitHub Repository	https://github.com/x03tanuj/sentinel-api
Live Web Dashboard	http://localhost:8080
Automated Demo Script	<code>bash scripts/demo.sh</code>
Architecture Diagram	docs/architecture.png (2400×1400)

Thank You! We are now open for Q&A.